

kerberos-nfs 설계·운영 매뉴얼

역할: FARM/LAB Kerberos·NFS의 운영 정책, 적용 상태, 키탭 관리와 수동 복구 근거를 소유한다.

1. 이 디렉터리의 성격

`kerberos-nfs` 는 일반 애플리케이션 패키지가 아니라 **운영 snapshot**과 **제한된 helper의 집합**이다. NAS export, AD identity, service principal, NFS mount는 서로 다른 시스템에 분산되어 있어 코드만으로 현재 상태를 설명할 수 없다. 따라서 실행 가능한 도구와 함께 적용 상태, 검증 결과, 과거 장애 근거를 보존한다.

이 디렉터리는 사용자별 keytab 생성이나 컨테이너 생성 transaction을 소유하지 않는다. 그 흐름은 `user-lifecycle`에 있다. 서버 전체 desired state와 일반적인 client bootstrap은 `server-state`, 지속적인 GSS/NFS 관측은 `monitoring`이 소유한다.

2. 디렉터리 지도와 신뢰 수준

경로	분류	사용 원칙
<code>README.md</code>	개요	기본 정책과 전체 위치 확인
<code>INVENTORY.md</code>	분류표	active/reference/risky/PoC 여부를 먼저 확인
<code>APPLIED_STATE.md</code>	적용 상태	FARM의 현재 검증된 mount profile 기준
<code>bin/</code>	active helper	사용법과 대상 host를 확인한 뒤 실행
<code>bin/recovery/</code>	수동 복구	운영 영향 검토와 명시적 승인 후 실행
<code>config/</code>	예제/reference	실제 <code>/etc/krb5.conf</code> 와 차이를 검토
<code>docs/farm/</code>	runbook/증거	최종 runbook을 우선하고 낱파 문서는 당시 증거로 해석
<code>systemd/user/</code>	로컬 자동화	NAS keytab watcher의 사용자 timer/service
<code>labs/lab-kerberos-poc/</code>	실험	운영 LAB 경로와 분리, 바로 production에 적용하지 않음
<code>reference/</code>	사본	실제 생성 소유자보다 우선하지 않음
<code>archive/</code>	과거 작업	현재 실행 경로로 사용하지 않음

`INVENTORY.md` 를 둔 이유는 shell script라는 형식만으로 현재 실행해도 되는 도구인지, 사고 당시 기록인지 구분할 수 없기 때문이다. 낱파가 오래되었다는 이유만으로 삭제하지 않고 증거로 남기되, active surface를 명시한다.

3. 현재 운영 원칙

3.1 기본 보안 flavor

FARM과 향후 LAB Kerberos client의 기본은 `sec=krb5` 다. 인증은 Kerberos로 보장하되 RPCSEC_GSS integrity/privacy wrapping의 추가 비용을 피한다. `sec=krb5i` 와 `sec=krb5p` 는 integrity 또는 privacy 요구가 성능 비용보다 중요한 명시적 경로와 시험에 사용한다.

과거 PoC 문서의 `sec=krb5p` 기록은 당시 시험 결과이며 현재 기본값을 뜻하지 않는다. 운영 기준은 `APPLIED_STATE.md` 와 최종 FARM runbook을 우선한다.

3.2 FARM mount profile

현재 문서화된 FARM 경로는 다음 형태다.

```
nas.farm.decs.internal:/volume1/share
-> /home/tako<N>/share

nfs4 vers=4.0,sec=krb5,proto=tcp,hard,
timeo=600,retrans=2,rsiz=1048576,wsiz=1048576,
addr=100.100.100.120,_netdev,exec,nouser
```

Synology가 실제 transfer size를 128 KiB로 협상할 수 있으므로 요청한 rsize와 실효값이 다른 것 자체를 장애로 보지 않는다. `hard` mount는 일시적인 NAS 장애에 데이터 오류를 반환하지 않는 대신 process가 D-state에 머물 수 있다. 이 때문에 timeout을 건 명령, readiness 순서, 포렌식이 별도로 필요하다.

3.3 identity 불변 조건

한 사용자에 대해 다음 값이 같아야 한다.

```
UID DB ubuntu_uid
= AD RFC2307 uidNumber
= NFS client에서 보이는 home owner UID
= container UID

primary GID도 같은 원칙 적용
```

이 일치를 확인하지 않은 채 `chown` 으로 증상만 고치면 NAS internal mapping, AD object와 DB가 더 어긋날 수 있다. identity 복구는 `farm-kerberos-identity-flow-policy` 와 RFC2307 recovery 문서를 함께 본다.

4. 핵심 기능

4.1 NAS NFS service keytab watcher

`bin/watch-farm-nas-nfs-keytab.sh` 는 FARM AD의 전용 계정 `svc-nfs-farm` 과 NAS의 `/etc/krb5.keytab` , `/etc/nfs/krb5.keytab` 을 비교한다. AD KVNO, 필요한 NFS principal, 현재 ticket 복호화 가능성을 점검하고 필요하면 새 keytab을 export·병합한 뒤 NAS에 원자적으로 교체한다.

```
# 변경 없이 점검
./bin/watch-farm-nas-nfs-keytab.sh --check --no-restart

# drift를 복구하되 GSS 재시작 여부는 영향 검토
./bin/watch-farm-nas-nfs-keytab.sh --repair
```

watcher의 repair와 AD password rotation은 다른 작업이다. timer는 drift를 수리할 수 있지만 AD 암호를 바꾸지 않는다. 자동 watcher가 key rotation까지 수행하면 일시적 네트워크 실패가 전체 NFS service key 변경으로 확대될 수 있기 때문이다.

4.2 계획된 service key rotation

`bin/rotate-farm-nfs-service-key.sh` 는 계정과 SPN 소유권을 먼저 확인한다. 실제 회전은 `--rotate --apply` 두 옵션을 모두 요구한다.

```
./bin/rotate-farm-nfs-service-key.sh --check
./bin/rotate-farm-nfs-service-key.sh --rotate --apply
```

회전은 새 random password, AD replication, 강제 watcher repair, NAS 적용이 한 묶음이다. 중간 실패 시 이전/새 KVNO와 NAS keytab의 principal을 각각 확인해야 한다. 유지보수 창과 활성 client 영향 확인 없이 실행하지 않는다.

4.3 FARM mount 복구

`bin/remount-farm-user-share-krb.sh` 는 현재 기본 `sec=krb5` profile로 FARM share를 복구하기 위한 helper다. mount 변경은 실행 중인 container와 user session에 영향을 주므로, 먼저 다음 chain을 확인한다.

1. `/etc/krb5.keytab` 존재와 machine principal
2. machine `kinit -k`
3. NFS service `kvno`
4. `rpc_pipefs` 와 `rpc-gssd`
5. 기존 mount와 D-state process
6. 대상 host를 제한한 remount

일반적인 기존 host 점검에는 `server-state` 의 `kerberos_nfs_client_recovery.yml` check mode를 먼저 사용할 수 있다.

4.4 복구 helper

`bin/recovery/`에는 NAS export 직접 수정, 잘못된 management-IP mount 제거, legacy `sec=sys` mount 제거, home artifact owner 수리 도구가 있다. 이름에 `recovery`가 붙었다는 사실을 실행 허가로 해석하면 안 된다. 대상과 현재 상태를 읽기 전용 명령으로 확인하고 script 내용을 검토한 뒤 사용한다.

특히 NAS export를 쓰는 helper는 설정 파일을 직접 변경하므로 backup, diff, NAS 서비스 반영 방법과 되돌리기 절차가 있어야 한다.

5. keytab과 ticket 모델

MIT Kerberos 대신 AD를 선택한 이유

MIT Kerberos KDC는 principal 인증과 ticket 발급을 담당하지만 Unix 사용자의 `uidNumber`, `gidNumber`와 group membership을 NAS에 제공하는 identity directory는 아니다. 별도 LDAP/NSS directory 없이 MIT Kerberos만 사용하면 NAS와 storage마다 사용자에게 대응하는 local account와 UID/GID를 생성·유지해야 했다.

이 방식은 사용자 계정이 compute server 외에 storage 장비까지 늘어나고, 퇴사·삭제 후 계정 잔존, UID/GID 불일치, 장비별 password·shell·권한 설정 drift가 생길 수 있어 보안과 운영 양쪽에서 적합하지 않다고 판단했다. 특히 NAS에 일반 사용자 계정을 직접 생성하는 것은 storage 관리 plane의 계정 공격 면을 불필요하게 넓힌다.

따라서 Kerberos 인증과 directory identity를 함께 제공하는 AD를 기준 identity source로 선택했다. AD의 RFC2307 `uidNumber`와 `gidNumber`, group membership을 compute host, container와 NAS가 공통으로 조회하므로 NAS에 사용자별 local login account를 중복 생성하지 않고도 같은 numeric identity로 NFS 권한을 판정할 수 있다. NAS에는 NFS service identity와 root-only service keytab만 두고, 사용자 identity와 group 정책은 AD에서 중앙 관리한다.

이 선택은 MIT Kerberos 자체가 안전하지 않다는 뜻이 아니다. MIT Kerberos에 별도의 LDAP/FreeIPA 같은 identity directory를 결합해도 같은 문제를 해결할 수 있다. 이 환경에서는 이미 필요한 Kerberos와 directory 역할을 한 체계에서 관리하고 NAS local account 생성을 피하기 위해 AD를 선택한 것이다.

NAS service identity

- AD의 전용 service account가 NFS SPN을 소유한다.
- NAS는 NFS service key가 포함된 root-only keytab을 가진다.
- watcher는 현재 AD KVNO와 NAS keytab을 검증한다.
- GSS service 재시작은 key 반영이 필요할 때만 수행한다.

사용자 identity

- 사용자 keytab 생성과 target host 설치의 `user-lifecycle`가 소유한다.
- keytab은 `/etc/decs-krb/keytabs/<user>.keytab`에 root-only로 둔다.
- systemd refresh가 `/run/user/<uid>/krb5cc`를 만든다.
- container에는 keytab이 아니라 ccache만 bind mount한다.

컨테이너 credential 경계

사용자 keytab은 반복해서 새 ticket을 발급할 수 있는 장기 자격증명이다. 한번 container 밖으로 복사되면 container를 삭제해도 keytab을 rotation하기 전까지 해당 principal로 ticket을 계속 발급받을 수 있다. 따라서 keytab은 target host의 root-only 영역에만 두고 image나 container mount에 포함하지 않는다.

container에는 이미 발급된 사용자별 ccache만 위임한다. ccache도 보호해야 하는 자격증명이지만 ticket 만료와 renew 범위가 있어 keytab보다 노출 범위가 작다. host refresh service는 임시 ccache를 만든 뒤 `klist`로 검증하고 사용자 소유권과 mode `0600`을 적용해 `/run/user/<uid>/krb5cc`로 원자 교체한다. container에는 이 경로와 `KRB5CCNAME`, 기대 principal, read-only `krb5.conf`만 전달한다.

이 분리는 Kerberized NFS home의 시작 순서도 해결한다. ticket이 없으면 home이 아직 writable하지 않을 수 있으므로 container가 password나 keytab으로 직접 `kinit`하지 않는다. container lifecycle과 분리된 host service가 ticket을 먼저 준비·갱신하고, container는 ccache가 유효해 home이 열릴 때까지 기다린다.

keytab을 제외하는 것만으로 credential 경계가 완성되지는 않는다. container에서 무제한 root가 허용되면 UID 전환, mount와 namespace 조작, `/run/user` 권한 변경을 통해 사용자별 ccache와 NFS identity 경계를 우회할 수 있다. Kerberos mode에서 `DECS_USER_SUDO_MODE=restricted`를 함께 적용하는 이유가 이것이다. 제한 정책은 UID 전환, 권한·mount 변경, root shell, interpreter one-liner와 보호 경로 쓰기를 차단하고, 필요한 사용자 그룹 공유는 일반 사용자 권한의 `group-dir-share`로 제공한다.

restricted sudo는 편의성과 위험 감소를 위한 정책이지 적대적 사용자를 막는 완전한 sandbox는 아니다. 강한 격리가 필요하면 sudo를 비활성화하고 `SYS_ADMIN` capability와 host bind mount 범위도 함께 줄여야 한다.

[reference/decs-krb-refresh](#)는 이 refresh logic의 참고 사본이다. 실제 생성 logic을 수정할 때는 `user-lifecycle/script/uid_manager/kerberos/`를 변경한다.

6. LAB PoC의 위치

[labs/lab-kerberos-poc/](#)는 Samba AD, NFSv4.1, 다양한 kernel/client 조합을 격리해 재현하기 위한 실험 영역이다. 운영 LAB share와 다른 export나 VM을 사용할 수 있으며, 결과 디렉터리는 성공·실패 당시의 증거다.

최근 VM slot regression 도구는 다음을 분리한다.

- VM provisioning과 isolated network
- AD/NFS server/client 구성
- kernel matrix 전환
- workload와 fault injection
- client/server capture와 결과 분석

PoC에서 성공한 설정도 운영 topology, idmap domain, 기존 mount와 사용자 영향을 검토한 뒤 `server-state`나 정식 playbook으로 승격해야 한다.

7. 다른 모듈과의 경계

작업	소유 모듈	이 디렉터리의 역할
사용자 AD/keytab/home 준비	user-lifecycle	정책·복구 근거 제공
host 공통 Kerberos client baseline	server-state	현재 mount/runbook 기준 제공
GSS readiness/canary/포렌식	monitoring	장애 해석과 운영 정책 제공
container ccache 소비	container-images	보안 모델 제공
NAS service key와 export	kerberos-nfs	직접 소유

동일한 shell 조각을 여러 모듈로 복사하지 말고, 위험한 NAS 작업은 이 디렉터리의 명시적 helper/runbook으로 되돌아오게 한다.

8. 장애 진단 순서

1. `findmnt` 로 source, target, `sec`, version과 실제 option을 확인한다.
2. `klist -k` 와 `kinit -k` 로 host keytab을 확인한다.
3. `kvno nfs/<storage-fqdn>@<REALM>` 으로 service ticket을 확인한다.
4. `rpc_pipefs`, `rpc-gssd`, journal 상태를 확인한다.
5. 사용자 ccache와 `klist` 를 해당 UID 권한으로 확인한다.
6. DB·AD RFC2307·NFS owner 숫자를 비교한다.
7. D-state와 mount responsiveness는 `monitoring` 지표와 포렌식 snapshot을 확인한다.
8. 공유 service 재시작이나 remount는 마지막 단계로 남긴다.

9. 문서 유지 규칙

- 새 helper는 `INVENTORY.md` 에 active/reference/risky 상태를 추가한다.
- 실제 production profile이 바뀌면 `APPLIED_STATE.md` 에 검증 시각과 대상을 기록한다.
- 실험 결과는 current default와 당시 실험 조건을 명확히 구분한다.
- keytab, 암호, local env, incident 개인정보와 대용량 capture를 커밋하지 않는다.
- 최종 runbook과 과거 rollout 문서가 충돌하면 최종 runbook과 적용 상태를 우선하고, 충돌 사실을 문서에 남긴다.